

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 4:	Pentest em Aplicações Web
Atividade 2:	Server-Side Request Forgery - SSRF
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Pentest em Aplicações Web*, para a qual utilizamos a sala do PortSwigger - <https://portswigger.net/>

No contexto desta sala, nosso foco é:

- 1) Alterar a URL de estoque para ter acesso de administrador e excluir o usuário carlos;
- 2) Acessar a interface <http://localhost/admin> passando pelo controle de lista negra e excluir o usuário carlos, com acesso de administrador;
- 3) Acessando o aplicativo local fazer um redirecionamento aberto para ter acesso de administrador e excluir o usuário carlos.
- 4) O que é o Server-Side Request Forgery (SSRF) - falsificação de solicitação do lado do servidor – é uma vulnerabilidade que permite que um agente malicioso modifique um servidor para realizar solicitações indevidas, para que o servidor informe dados internos confidenciais, serviços restritos, ativos protegidos, metadados de servidores em nuvem, elevação de privilégios e movimentação lateral dentro de uma infraestrutura, explorando a confiança do servidor na rede interna para obter informações ou realizar novos ataques.

A sala do Portswigger é composta por três tarefas:

- 1) SSRF básico contra outro sistema back-end - <https://portswigger.net/web-security/ssrf/lab-basic-ssrf-against-localhost>
- 2) SSRF com filtro de entrada baseado em lista negra - <https://portswigger.net/web-security/ssrf/lab-ssrf-with-blacklist-filter>

- 3) SSRF com desvio de filtro via redirecionamento aberto
<https://portswigger.net/web-security/ssrf/lab-ssrf-filter-bypass-via-open>

[redirection](#)

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

- 1) Acessar os sites informados acima.
- 2) Utilizar a VM do Kali Linux: Para utilizar o Burp e executar alguns comandos no terminal.

2.2. Atividade prática

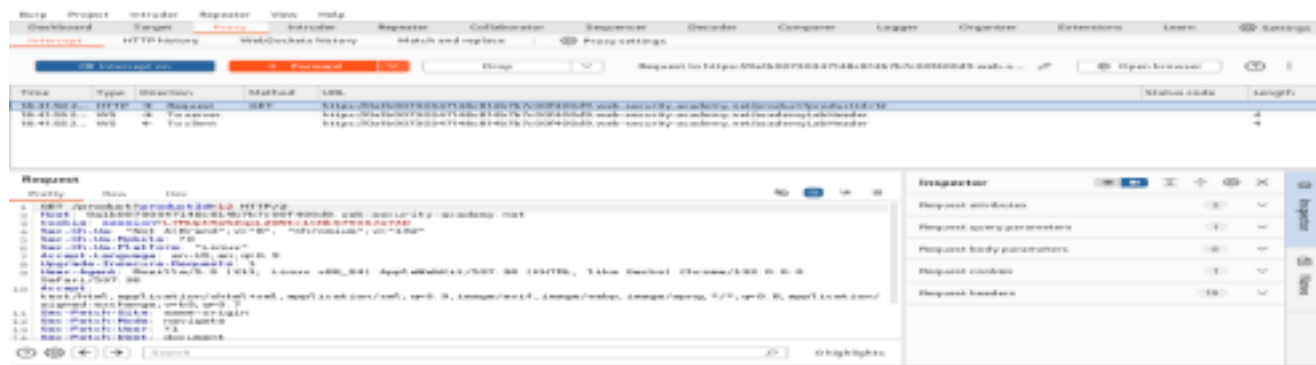
O objetivo desta atividade é realizar as 3 tarefas propostas no PortSwigger.

2.3. Atividade 1 - SSRF básico contra outro sistema back-end.

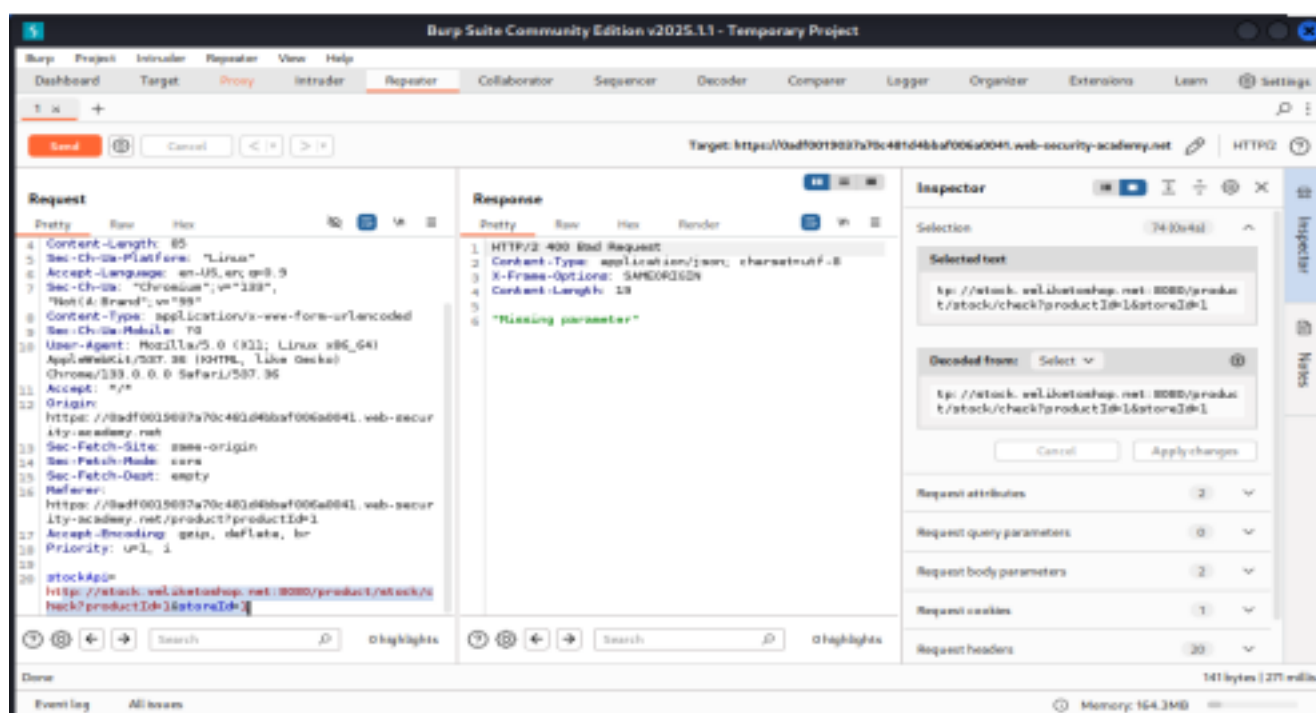
Passo 1 – Entre com seu login e senha no PortSwigger no site: <https://portswigger.net/web-security/ssrf/lab-basic-ssrf-against-localhost> e clique em acesse o laboratório, e depois clique em giant pillow thing



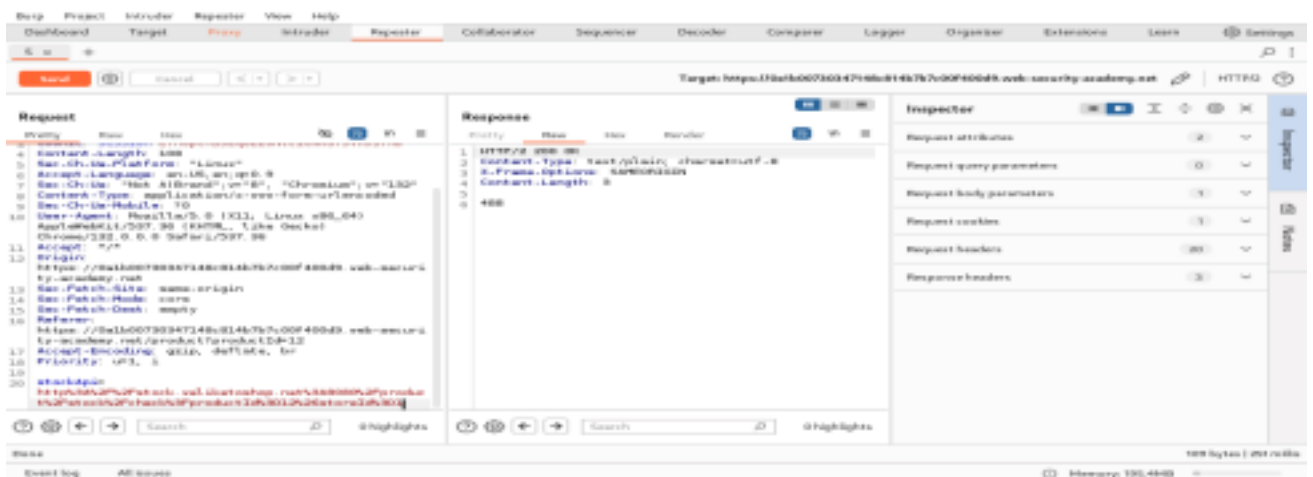
Passo 2 – Vá até o Burp clique em Intercept On na requisição GET, no Request clique com o botão direito e clique em Send to Repeater



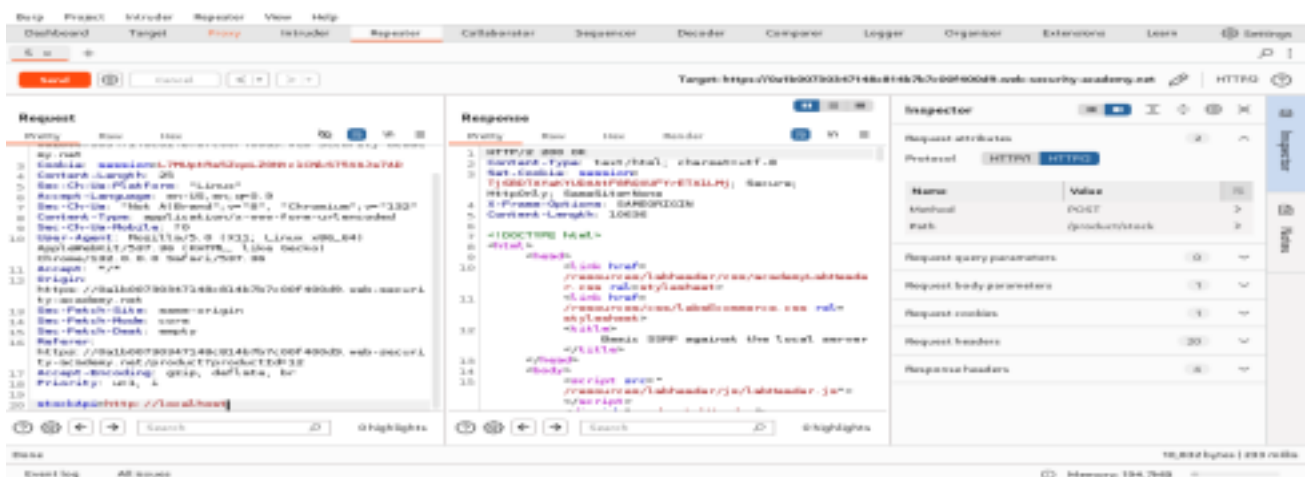
Passo 3 – No Repeater em Request vá até o fim da página em StockApi e na URL que aparecer clique com o botão direito do mouse em convert selection/URL/URL Decode e clique em Send



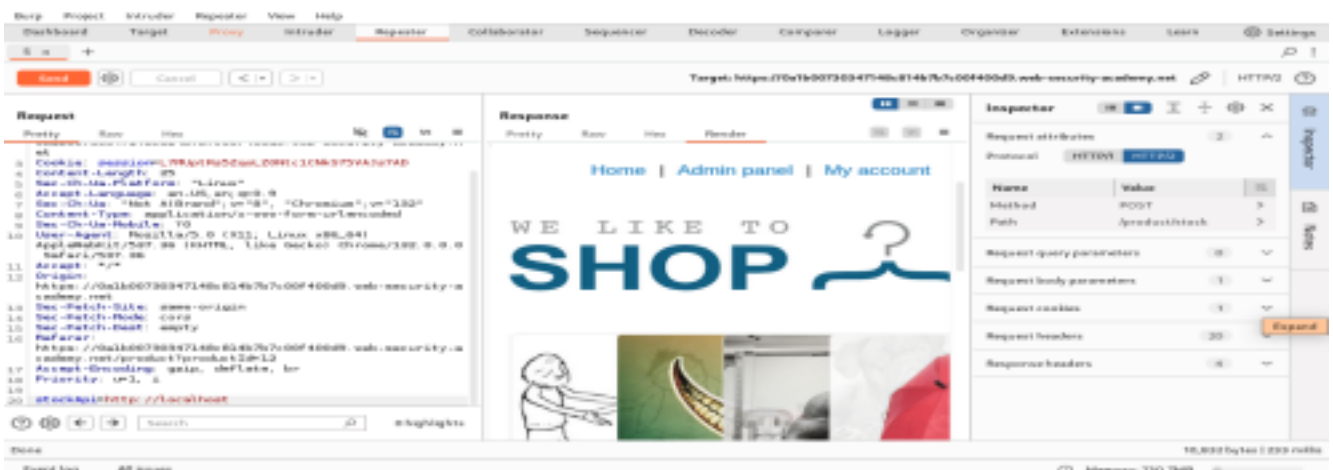
Passo 4 – Depois selecione o StockApi e novamente codifique a URL, clique com o botão direito do mouse em convert selection/URL/Encode all characters (Unicode), aparece o número que tem no estoque neste caso 488 -> verificar



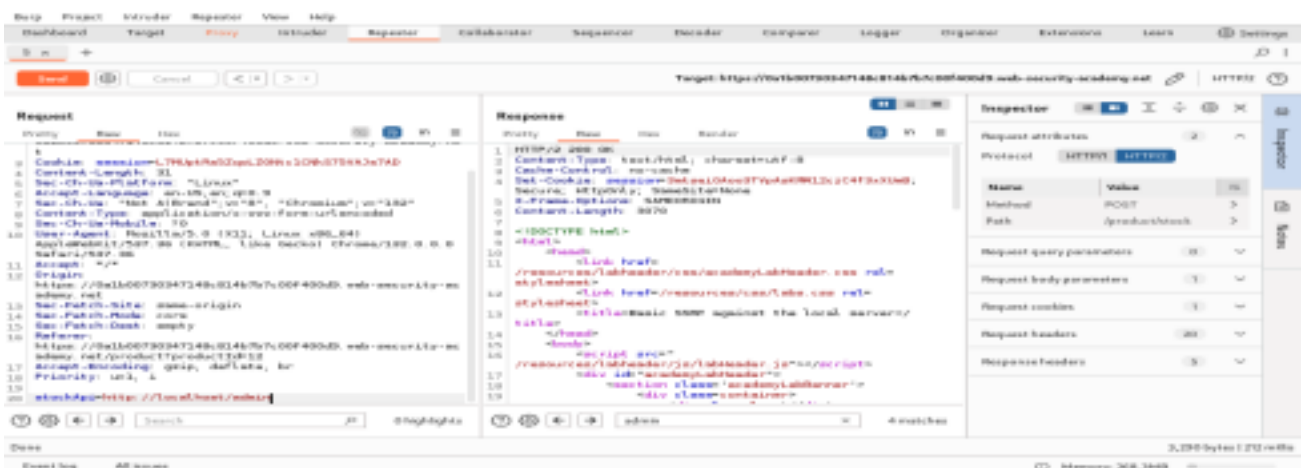
Passo 5 – Verificar se aceita o endereço de localhost é vulnerável a SSRF <http://localhost/> no campo stockApi e clique em Send e vemos que conseguimos entrar nesta página.



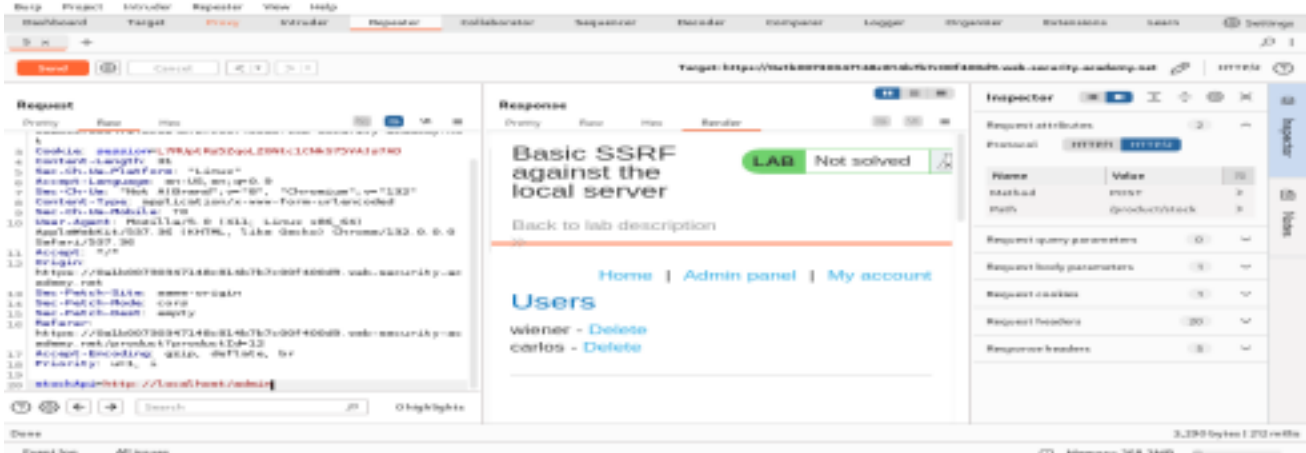
Passo 6 – Clique em Render verificará que temos a mesma página de antes, porém com o botão Admin Panel que só aparece para administradores.



Passo 7 – Em Response clicamos em Raw e procuramos pela palavra admin, conseguimos verificar que temos uma referência em /admin e vamos colocar isso na nossa URL de Request <http://localhost/admin> e clique em Send a solicitação foi aceita pelo código 200.

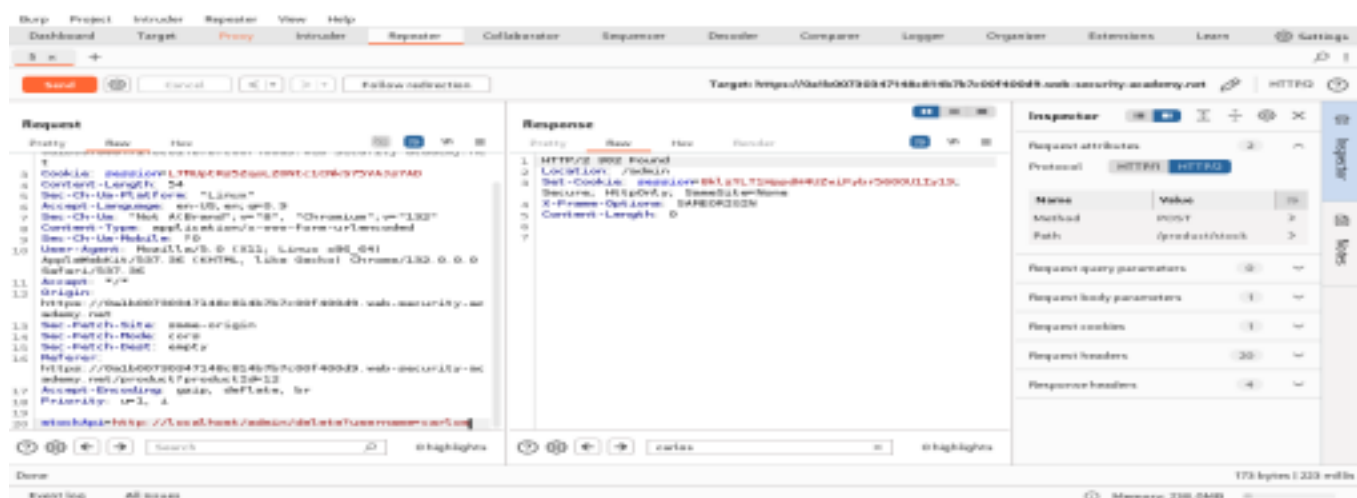


Passo 8 – Clique em Render e aparecerá a tela com os usuários carlos e wiener para deletar.

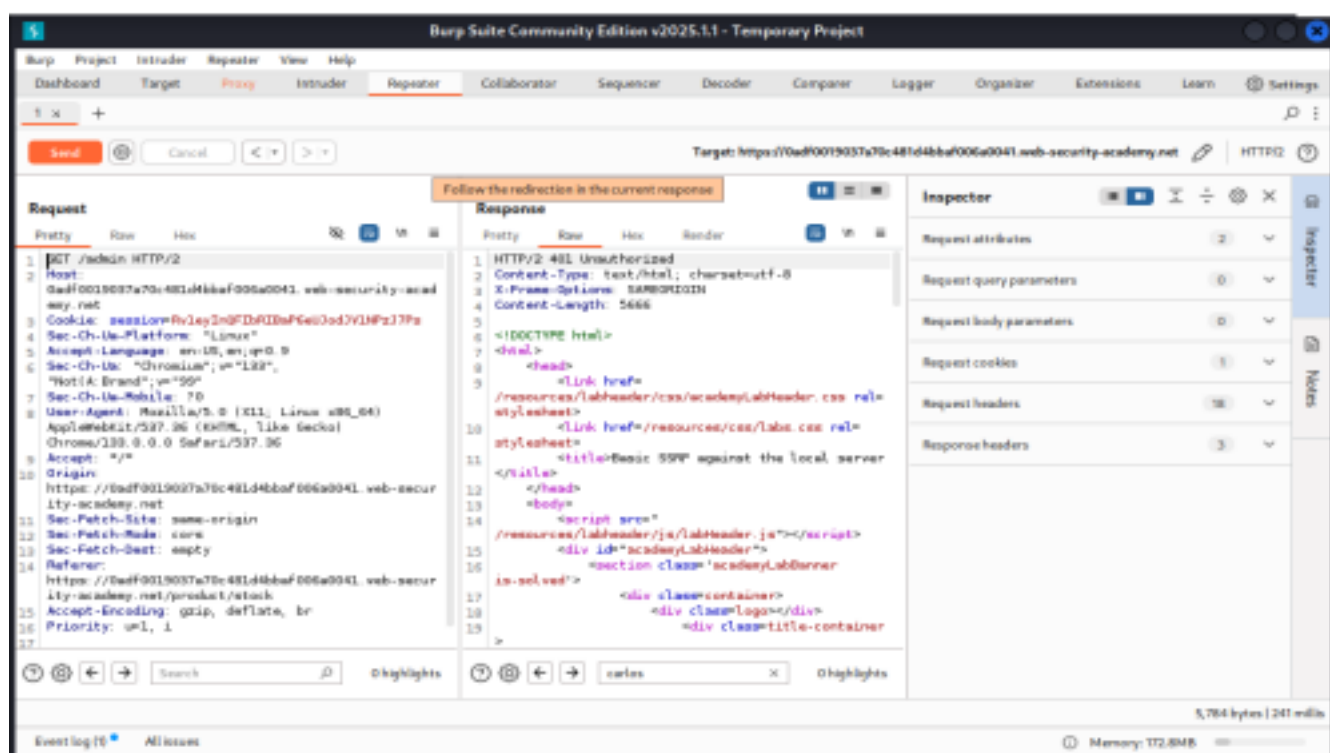


5

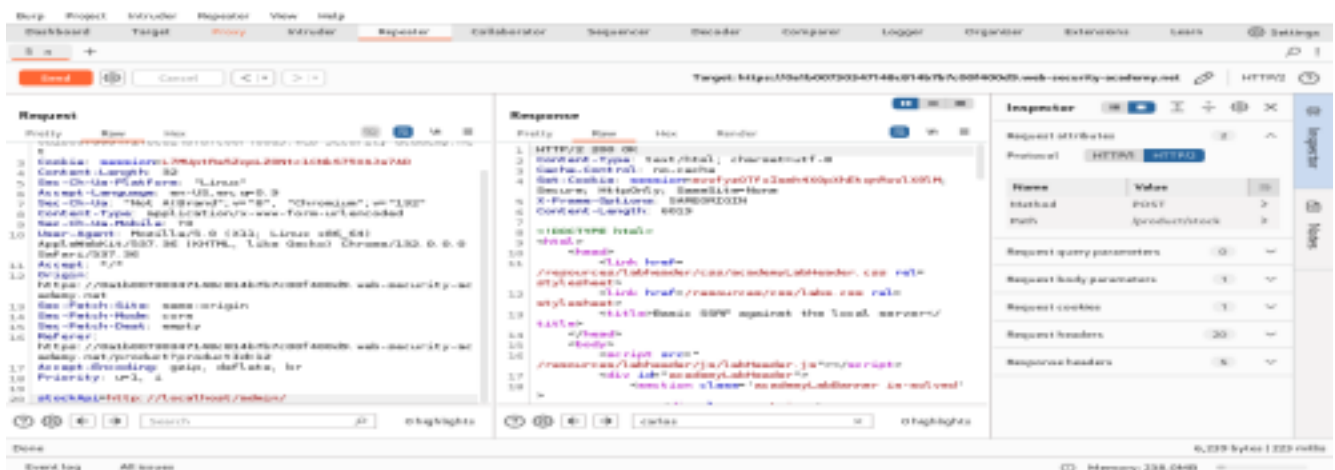
Passo 9 – No Response volte até o Raw e procure por carlos e vamos encontrar um caminho para deletar o usuário carlos /admin/delete?username=carlos copie o caminho e colamos no Request no stockAPI a seguinte URL <http://localhost/admin/delete?username=carlos>, clique em Send e teremos um código 302



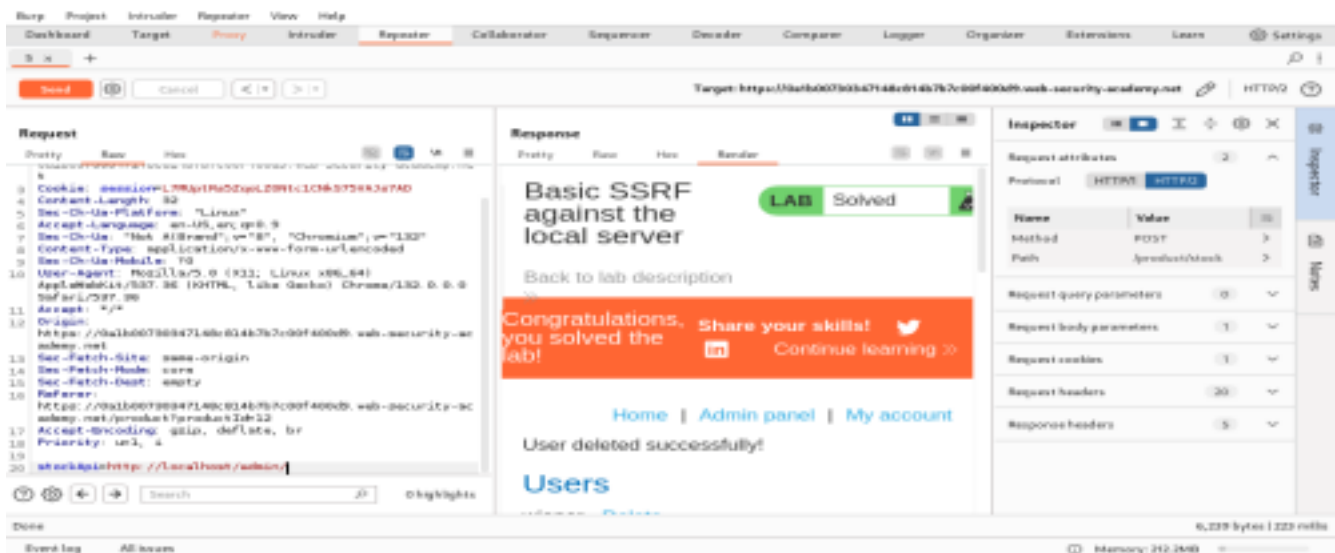
Passo 10 – Depois clique em Follow Redirection e aparecerá no Response que não está autorizado código 401.



Passo 11 – Volte no request e coloque no StockApi o endereço <http://localhost/admin> e clique em Send aparecerá o código 200 OK



Passo 12 – No Response clique em Render e o usuário carlos não aparece mais e o laboratório está concluído. - > verificar se não tem outra figura com o carlos excluído.

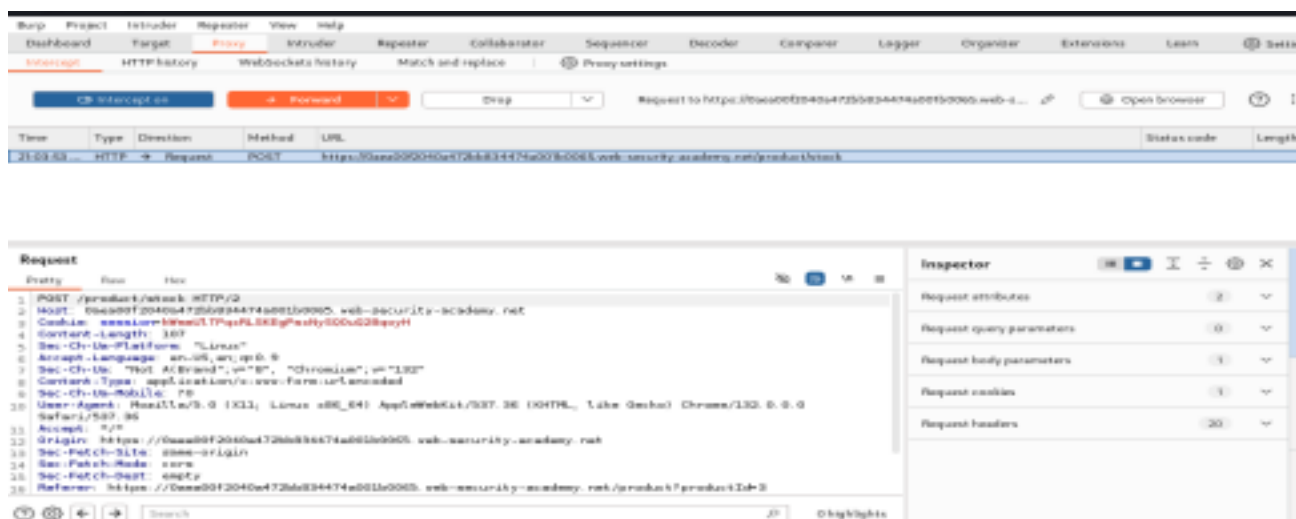


2.4. Atividade 2 – SSRF com filtro de entrada baseado em lista negra

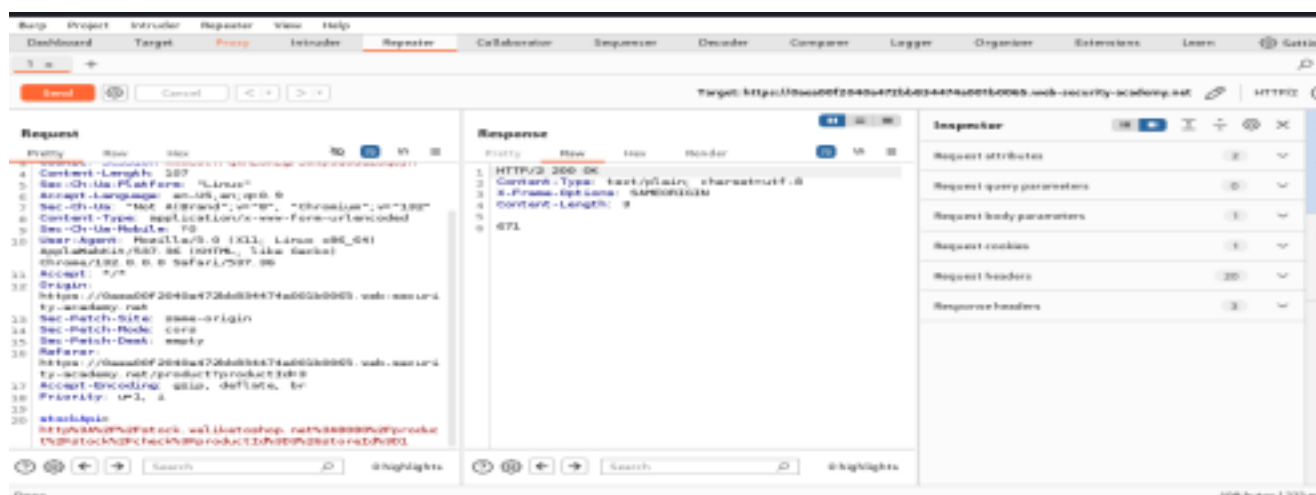
Passo 1 – Aparecerá o site <https://0ada009bo370a80f8cd74540021001f.web-security-academy.net>, clique em Hologram Stand In e em Check stock



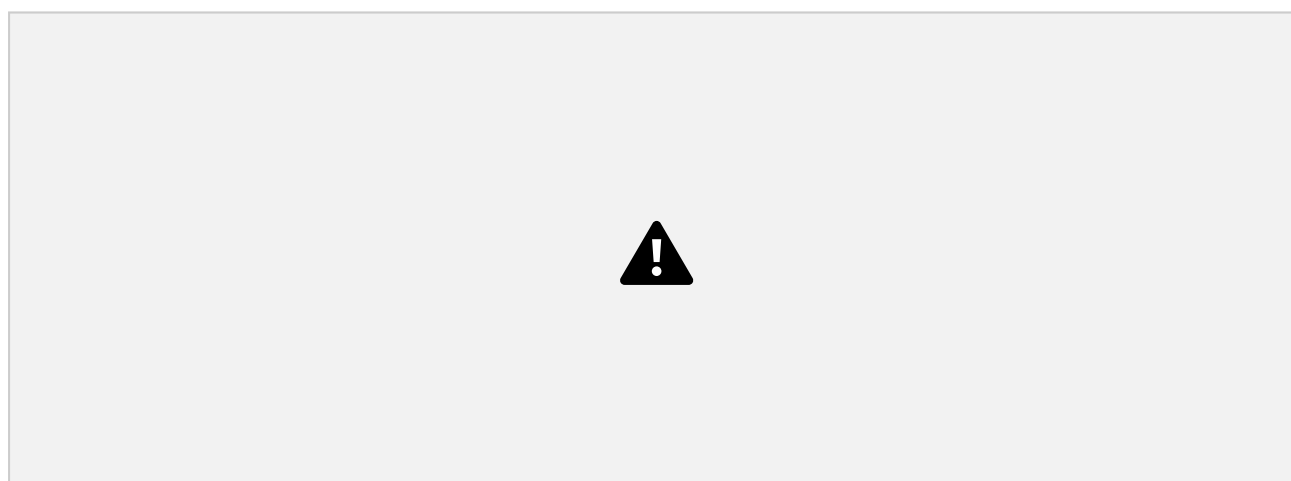
Passo 2 – Vá até o Burp e clique em Send To Repeater



Passo 3 – No Repeater clique em Send e aparecerá o código 200 OK para a URL informada e a quantidade em estoque daquele produto neste caso são 671.



Passo 4 – Verificamos se ele aceita o comando <http://localhost/> e quando clicamos em Send a Response vem com o código 400 Bad Request e uma mensagem External Stock blocked for security reasons.



Passo 5 – Substituímos a URL por <http://127.0.0.1/> mas acontece a mesma resposta.



Passo 6 – Depois colocamos a URL <http://127.1> para conseguir uma resposta 200 OK



Passo 7 – Clique em Render e aparecerá que o Admin Panel que só aparece quando é administrador.



10

Passo 8 – Agora clicamos em Raw e procuramos por admin e vamos encontrar /admin e colocamos na stockapi <http://127.1/admin>, clicamos em Send mas a resposta é 400 Bad Request, e uma mensagem External Stock blocked for security reasons.



Passo 9 – Agora vou selecionar a primeira letra de admin com o botão direito clique em convert selection/URL/encode all characters e depois novamente seleciono o que foi convertido e faço o mesmo processo e com isso recebemos um código 200 OK.



Passo 10 – Clique em Render e verá que tem acesso de administrador.



Passo 11 – Agora em Response vamos na guia Raw e procurar pelo nome carlos, achamos o /admin/delete?username=carlos, em Request colamos a seguinte URL no stockApi <http://127.1/%25%36%31dmin/delete?username=carlos> e clique em Send e teremos código 302 Encontrado



Passo 12 – Clique em Follow Redirection e aparecerá um código 401 Não Autorizado.



12

Passo 13 – No request em stockapi digite <http://127.1/%25%36%31dmin/> e o laboratório estará concluído e o usuário carlos deletado.



2.5. Atividade 3 – SSRF com desvio de filtro via redirecionamento aberto.

Passo 1 – Acesse o site, clique na figura more than just birdsong e clique em Check Stock



Passo 2 – Va até o Burp intercept on em Raw clique em Send To Repeater.



13

Passo 3 – Volte no site e clique em next-product e no Burp clique novamente em Send To Repeater.



Passo 4 –No Repeater renomeie as abas para check-stock e next-product, em check stock em Raw vá até o stockAPI selecione a URL clique com o botão direito do mouse convert selection/URL/URL Decode e clique em Send irá aparecer o código 400 Bad Request.



Passo 5 – Agora retorne para a URL anterior e clique em Send aparecerá o código 200 OK e a quantidade do estoque, neste caso 161.



Passo 6 – Agora vamos verificar se a URL de localhost funciona, verificamos que a URL não funciona aparece o código 400 Bad Request e a mensagem invalid external stock url 'Invalid URL' ”



Passo 7 – Agora clique na aba next-product. clique em Send aparecerá o código 302 Encontrado e depois em Follow Redirection e aparecerá o código 200 OK.



Passo 8 – Volte na setinha ao lado de cancel e apague até path= depois coloque <https://www.google.com> e clique em Send aparecerá o código 302 Encontrado, depois clique em Follow Redirection e depois em Render aparecerá a página do Google.



Passo 9 – Na guia de check-stock em stock-API apague tudo até o sinal de =, depois vá na guia de next-product e copie a URL /product/nextProduct?currentProductId=1&path=/product?productId=2 e cole na guia checkstock em stock-api depois vai deletar até o path = e colocar a seguinte URL <http://192.168.0.12:8080/admin> e quando clicamos em Send aparece o código 400 Bad Request e a mensagem “missing parameter ‘path’ “



Passo 10 – Agora vamos selecionar a URL do stockApi /product/nextProduct?/currentProductId=3&path=http://192.168.0.12:8080/admin clicar com o botão direito do mouse convert selection/URL/URL encode key-characters, clique em Send e depois em Render verá que tem o acesso de administrador com o menu de Admin Panel.



Passo 11 – Em Response clique em Raw e procure por carlos e copie toda a URL <http://192.168.0.12:8080/admin/delete?username=carlos> cole depois da URL que já está no stockApi clique com o botão direito do mouse convert selection/URL/URL-encode all characters, clique em Send e receberemos o código 200 OK



Passo 12 – Clique em Render o usuário carlos foi deletado e o laboratório está concluído.



2.6. Análise dos Resultados:

Foi realizada a instalação do Burp Community no Kali Linux

Interpretação dos resultados:

- 1) Na Atividade 1 - SSRF básico contra outro sistema back-end: Aprendemos a codificar e decodificar a URL no BURP pois alguns caminhos só funcionam se estiver codificado ou decodificado, este site é vulnerável a SSRP colocando a URL <http://localhost/> no stockAPI, tivemos o acesso administrador com o /admin, encontramos a url para excluir o carlos <http://localhost/admin/delete?username=carlos> voltamos na URL <http://localhost/admin> e vemos que o usuário carlos foi excluído.
- 2) Na Atividade 2 - SSRF com filtro de entrada baseado em lista negra: Não aceita o comando <http://localhost> aparece a mensagem que o acesso externo está bloqueado

tentamos colocar o endereço de localhost em números e não foi possível também, colocamos apenas 127.1 e foi possível pois ele completa os octetos faltantes ultrapassando a barreira da black list, tivemos o acesso de administrador, depois codificamos 2 vezes a letra a, depois excluimos o carlos através da URL <http://127.1/%25%36%31dmin/delete?username=carlos> e entramos novamente como administrador através do endereço <http://127.1/%25%36%31dmin/> confirmando que o usuário carlos foi excluído.

- 3) Na Atividade 3 - SSRF com desvio de filtro via redirecionamento aberto: Neste laboratório 3 utilizaremos duas abas no repeater a aba check-stock e next-product, verificamos que a URL localhost não funciona neste laboratório aparece a mensagem de url inválida, vamos manipular o path para ele redirecionar ao google <https://www.google.com>, selecionamos a URL do stockApi /product/nextProduct?/currentProductId=3&path=http://192.168.0.12:8080/admin convertemos url-encode all characters e terá acesso de administrador, agora excluir o usuário carlos convertemos novamente em url-encode all characters <http://192.168.0.12:8080/admin/delete?username=carlos> clique em send e receberemos o código 200 OK, clique em Render e o usuário carlos está excluído.

2.7. Mitigação:

- 1) No laboratório 1: Não podemos deixar a vulnerabilidade SSRF no campo de stockApi, pois no Burp podemos substituir por um localhost e ter acesso de administrador, temos que implantar uma White list com o que é permitido e negar o resto por padrão;
- 2) No laboratório 2: Temos que implantar uma White list com os comandos que podem ser utilizados e o restante negamos por padrão para que não aconteça de conseguir burlar as regras por outros meios;
- 3) No laboratório 3: Não pode deixar a variável de caminho path exposta pois só irá validar a primeira URL podendo fazer direcionamentos para qualquer site; 4) Sanitização de dados em requisições de usuários: para evitar requisições indevidas em um campo que o usuário tem o controle e temos que fazer esta validação.; 5) Segmentação de redes: para diminuir o alcance de um possível ataque, para que não se espalhe a outros servidores e possa prejudicar ainda mais o funcionamento da rede;
- 6) Bloqueio de acesso indesejados: verificar se é necessário que um servidor esteja voltado para a internet, se é preciso que um determinado servidor fique ativo todo o tempo e bloquear qualquer requisição suspeita.

3. Considerações finais

Nesta sala, exploramos técnicas Pentest em Aplicações Web com o software Burp Suite Community para manipular algumas requisições, utilizando o Repeater para enviar requisições automaticamente, codificamos e decodificamos URL's, utilizamos SSRF básico

colocando localhost para ter acesso administrativo, burlamos uma black list e conseguimos acesso de administrador através de um IP que já tínhamos e codificando a URL.

As principais lições aprendidas incluem:

- 1) O aplicativo não pode estar rodando diretamente no servidor sem autenticação, porque presume-se que se chegou até o servidor você já está autenticado e com acesso de administrador, o servidor não tem que confiar em nenhum processo zero trust, sempre solicitar o login em qualquer requisição.
- 2) Não utilizar black list pois pode-se contornar as regras de outras formas e este processo não é efetivo para evitar SSRF.
- 3) O redirecionamento aberto é muito perigoso pois pode direcionar para qualquer site malicioso inclusive de bancos, contas de água, energia fazendo com que os seus dados fiquem expostos, ecommerce para conseguir os dados do cartão de crédito.
- 4) Bypass de filtro - é um método ou técnica para evitar medidas de segurança de filtros caso façamos uma lista estática de URL, escrevendo as URL's de outras formas para que o servidor aceite o nosso comando, exemplo: no IPV4 em vez de 127.0.0.1 pode utilizar IPV6 ::1 para tentar enganar o servidor, podemos utilizar também números hexadecimal, decimal e octal para alcançar nosso objetivo de burlar a lista estática, podemos também omitir alguns números como fizemos no laboratório, podemos misturar hexadecimal com binário e outras combinações ou fazer um overflow ou seja um número maior que ele pode ler exemplo: 899.0.2.259.

Foi verificado que o Burp também é bem fácil de utilizar e tem recursos que deixam a manipulação do site ainda mais fácil como o Repeater, vimos formas de burlar o sistema através de números colocando apenas o endereço 127.1/ ou através de um endereço IP interno codificando para que nos desse o acesso administrador.

4. Referências

Site: <https://portswigger.net/web-security/ssrf/lab-basic-ssrf-against-localhost> Site:

<https://portswigger.net/web-security/ssrf/lab-ssrf-with-blacklist-filter>

Site: <https://portswigger.net/web-security/ssrf/lab-ssrf-filter-bypass-via-open-redirection>

Site: <https://h2it.com.br/glossario/o-que-e-bypass-de-seguranca/>

